

Enumeracion de LDAP

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

LDAP (puerto 389, o 636 cifrado) es el protocolo que Active Directory (y otros directorios) usan para almacenar y consultar usuarios, grupos, equipos y su estructura organizativa. Muchos servidores permiten un 'bind anonimo' (conectar sin credenciales) que, aunque limitado, a veces basta para leer el naming context y enumerar usuarios.

El bind anonimo existe para operaciones basicas de consulta sin necesitar cuenta, pero si el administrador no lo restringe, expone la estructura del directorio (nombres de usuario, grupos, a veces atributos sensibles) a cualquiera que se conecte, sin autenticar. Es el equivalente en AD de la sesion nula de smb-enum.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando el recon confirma un DC (puerto 389/636 abierto junto a 88 Kerberos y 445 SMB). Es parte del arranque de la fase AD: mira tambien ad-modelo.

Cómo identificarla

- Puertos 389/636 abiertos junto a 88 (Kerberos) y 445 (SMB): confirma que es un DC.
- Ldapsearch sin credenciales (bind anonimo) devuelve resultados en vez de error de autenticacion.
- El naming context revela el nombre del dominio en formato DC=...

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Intenta un bind anonimo y pide el naming context base con ldapsearch.

Evidencia esperada: Una respuesta con el defaultNamingContext (algo como DC=dominio,DC=local) confirma que el bind anonimo funciona y puedes consultar el directorio.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.

3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
ldapsearch -x -H ldap://$IP -s base namingcontexts
```

Objetivo y contexto: Bind anonimo (-x sin credenciales) pidiendo el naming context base. Es la prueba mínima: si responde, el bind anonimo esta permitido.

Resultado esperado: Un defaultNamingContext tipo DC=corp,DC=local. Confirma el nombre del dominio y que puedes seguir consultando sin credenciales.

Capa 2: prueba documentada

```
ldapsearch -x -H ldap://$IP -D '' -w '' -b 'DC=corp,DC=local' '(objectClass=user)'
```

Objetivo y contexto: Con el naming context ya conocido, pide todos los objetos de tipo usuario via bind anonimo. Es la enumeracion completa de usuarios sin credenciales.

Resultado esperado: Una lista de usuarios del dominio con sus atributos visibles. Extrae los nombres para spraying o Kerberoasting.

Anatomía de los payloads

La primera prueba es `ldapsearch -x -H ldap://$IP -s base namingcontexts`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Una respuesta con el defaultNamingContext (algo como DC=dominio,DC=local) confirma que el bind anonimo funciona y puedes consultar el directorio.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Prueba el bind anonimo pidiendo el naming context base; te confirma si esta permitido y te da el nombre del dominio.
- Si el bind anonimo funciona, enumera usuarios y grupos con una consulta mas amplia (base DN completo).
- Con una credencial (aunque sea debil), repite la consulta: el bind autenticado suele revelar mucho mas que el anonimo.
- Los usuarios que saques alimentan spraying y roasting: mira `asrep-kberoast`.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- El servidor rechaza el bind anonimo (necesitas credenciales validas para cualquier consulta).
- No es un entorno AD/LDAP: el puerto 389 no responde o pertenece a otro servicio.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

LDAP guarda el directorio de usuarios y grupos de un dominio; un bind anonimo te deja consultarlo sin credenciales. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y precondiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook \(ldap-enum\)](#)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.